

UNIVERSIDAD PERUANA UNIÓN

Facultad de Ingeniería y Arquitectura

Escuela Profesional de Ingeniería de Sistemas

img/logo-upeu.png

CE032

Entregable 2: Planificación de Seguridad de la Información

Área: Infraestructura Tecnológica

Asesor: Mg. Fernando Asin

Integrantes:

Integrante
Salazar Tocas, Rubén Mark
Chavarri Centeno, Jorge Andrés
Sauñe Fernandez, Uziel Elias
Pedraza Perez, Joshua Josue
Lanche Cerro, Hilter Piero
Rivera Matias, Joel Joshep
Evan Chacon
Ramos Turpo, Roxwell Jesus
Vallejos Cotrina, Pamela
Vergara, Veronica Lisseth

Junio, 2026

Versión	Fecha	Autor	Descripción	Estado
v1.0	31/05/2026	Salazar Tocas, R.	Creación inicial: CE0321–CE0325 completos	Aprobado
v1.1	01/06/2026	Sauñe Fernandez, U.	Referencias normativas (9 docs) y eliminación de anexo redundante	Aprobado

Índice

1	CE0321 - Identificación y Valoración de Activos de Información	1
1.1	Metodología de identificación y valoración de activos	2
1.2	Inventario de activos primarios: datos e información	3
1.3	Inventario de activos primarios: servicios y procesos de negocio	3
1.4	Inventario de activos secundarios: software, hardware, red y personas	3
1.5	Síntesis del inventario y activos críticos prioritarios	3
2	CE0322 - Análisis y Tratamiento de Riesgos de Seguridad	6
2.1	Metodología de análisis de riesgos	7
2.2	Matriz de riesgos identificados	7
2.3	Mapeo a los dominios del NIST CSF y plan de tratamiento	7
3	CE0323 - Políticas de Seguridad de la Información	8
3.1	Marco general de las políticas de seguridad	9
3.2	POL-01 — Política de control de acceso	9
3.3	POL-02 — Política de gestión de contraseñas	10
3.4	POL-03 — Política de respaldo y recuperación	11
3.5	POL-04 — Política de gestión de parches y actualizaciones	12
3.6	POL-05 — Política de uso aceptable de los recursos de TI	13
3.7	POL-06 — Política de respuesta a incidentes de seguridad	14
3.8	Cobertura de las políticas frente a los riesgos identificados	16
4	CE0324 - Roles, Responsabilidades y Matriz RACI del SGSI	17
4.1	Estructura organizacional de seguridad de TI	18
4.2	Matriz RACI de procesos de seguridad	19
4.3	Responsabilidades operativas por frecuencia	19
4.4	Vinculación de los roles con los controles de ISO 27001:2022	21
5	CE0325 - Calidad Documental y Ética Profesional del Entregable 2	22
5.1	Propósito del cierre documental y ético	23
5.2	Revisión de coherencia del Entregable 2	23
5.3	Aplicación del Código de Ética de la ACM	26
5.4	Impacto social, legal y responsabilidad profesional	27

5.5	Declaración de calidad documental y ética del Entregable 2	28
5.6	Cierre del Entregable 2	29
A	Anexo A — Inventario de Activos Primarios — Datos e Información	31
B	Anexo B — Inventario de Activos Primarios — Servicios y Procesos de Negocio	34
C	Anexo C — Inventario de Activos Secundarios — Software, Hardware, Red y Personas	37
C.0.1	Software de infraestructura	38
C.0.2	Hardware	38
C.0.3	Infraestructura de red y personas	39
D	Anexo D — Matriz Completa de Riesgos Identificados	41
D.1	Mapa de calor de probabilidad e impacto	46
E	Anexo E — Mapeo al NIST CSF y Plan de Tratamiento de Riesgos	47
E.1	Resultado del análisis de riesgos	52
F	Anexo F — Matriz RACI de Procesos de Seguridad	53
	Referencias Bibliográficas	56

CAPÍTULO 1

CE0321 - Identificación y Valoración de Activos de Información

1.1 Metodología de identificación y valoración de activos

La planificación de la seguridad de la información para Franco's SAC se inicia con la identificación de los activos que sostienen la operación del negocio. Un activo, en el sentido de **(author?)** [1], es cualquier elemento que tiene valor para la organización y que, por lo tanto, requiere protección frente a amenazas que puedan comprometer su confidencialidad, integridad o disponibilidad.

Para este entregable se reconocen seis categorías de activos: datos e información, servicios y procesos de negocio, software de infraestructura, hardware, infraestructura de red y personas. Esta clasificación sigue la estructura del Anexo B de **(author?)** [1], que diferencia entre activos primarios –información y procesos– y activos secundarios –los elementos técnicos y humanos que sostienen a los primeros.

La valoración de cada activo se realiza mediante el modelo CIA (*Confidentiality, Integrity, Availability*), en una escala de 1 a 5 para cada dimensión. Esta valoración es el insumo directo del análisis de riesgos desarrollado en el CE0322, ya que un activo con valor alto exige un tratamiento de riesgo más exigente que uno de valor bajo.

Tabla 1. Escala de valoración CIA aplicada a los activos de Franco's SAC

Valor	Nivel	Significado
5	Crítico	La pérdida o el compromiso del activo paraliza completamente las operaciones del negocio.
4	Alto	Impacto severo: pérdida económica significativa o daño legal y reputacional grave.
3	Medio	Impacto importante pero recuperable en el corto plazo.
2	Bajo	Impacto menor; la operación puede continuar con una degradación leve.
1	Mínimo	Sin impacto operativo significativo.

El valor final de cada activo se calcula como el máximo entre sus tres dimensiones: $\text{Valor} = \max(C, I, A)$. A partir de este valor se aplica la siguiente clasificación: valor 5 equivale a **crítico**, valor 4 a **alto**, valor 3 a **importante** y valores 1–2 a **normal**. Esta regla evita que un activo con una sola dimensión crítica –por ejemplo, disponibilidad– sea subestimado por tener confidencialidad o integridad bajas.

1.2 Inventario de activos primarios: datos e información

Los activos de datos e información constituyen el núcleo del ERP de Franco's SAC. Incluyen las bases de datos operativas PostgreSQL, los respaldos generados a partir de ellas y las configuraciones que permiten reconstruir la infraestructura ante un incidente. Estos activos concentran los valores CIA más altos del inventario porque su pérdida o corrupción afecta directamente la continuidad del negocio y, en el caso de datos personales, genera responsabilidad legal conforme a la Ley N.º 29733.

1.3 Inventario de activos primarios: servicios y procesos de negocio

Los servicios y procesos de negocio representan la operación visible de Franco's SAC: el ERP (frontend Angular + API Gateway + microservicios NestJS), la autenticación corporativa vía Active Directory, la conectividad VPN hub-and-spoke entre sedes, la resolución de nombres (DNS interno), el monitoreo centralizado Wazuh y los respaldos automatizados a S3. Su indisponibilidad no implica pérdida de datos pero sí interrupción del proceso de negocio.

1.4 Inventario de activos secundarios: software, hardware, red y personas

Los activos secundarios sostienen técnica y humanamente a los activos primarios. Se agrupan en cuatro subcategorías: **software de infraestructura** (VMware ESXi 8.0, pfSense CE 2.7, Windows Server 2022, Docker, Wazuh, Veeam), **hardware** (5 hipervisores, switches gestionables, FortiGate 40F, router Cisco), **infraestructura de red** (VLANs, túneles VPN, port groups ESXi) y **personas** (6 roles del SGSI con nivel de criticidad según su conocimiento operativo).

1.5 Síntesis del inventario y activos críticos prioritarios

El inventario consolidado reúne 28 activos distribuidos en las seis categorías descritas: nueve activos alcanzan valor 5 (crítico), diez alcanzan valor 4 (alto) y los nueve restantes se ubican en valor 3 o menor (importante o normal). Esta distribución confirma que la infraestructura de Franco's SAC concentra su criticidad en un núcleo reducido de activos –las bases de datos del ERP, el directorio activo, pfSense y los hipervisores de la Sede Central– y no de manera uniforme en todo el inventario.

Tabla 2. Activos más críticos del inventario, en orden de prioridad

Prioridad	Activo	Categoría	Justificación de la criticidad
1.º	person-db (D-01)	Datos	Contiene datos personales sujetos a la Ley N.º 29733. Su compromiso implica sanción legal, pérdida de confianza y paralización del microservicio de autenticación.
2.º	pfSense 2.7 CE (SW-01)	Software	Concentra todos los túneles VPN. Si falla, Local 1 y Local 3 quedan aislados, se pierde la salida a Internet y el ERP deja de ser accesible externamente.
3.º	ERP completo (S-01)	Servicio	Proceso de negocio principal; su caída paraliza ventas, inventario y producción.
4.º	Active Directory (S-02)	Servicio	Sin AD, ningún usuario puede autenticarse en el dominio. Impacta a la totalidad de los trabajadores.
5.º	sales-invent-db	Datos	Base de datos operativa del negocio; su corrupción implica pérdida del historial de ventas e inventario.
6.º	ESXi H1–H3 (HW-01/02)	Hardware	Hipervisores que alojan toda la infraestructura de la Sede Central; su falla implica la caída de todos los servicios.
7.º	Samba AD-DC 4.x (SW-03)	Software	Motor del directorio activo. Su corrupción implica pérdida de credenciales y políticas, sin réplica on-premises tras la eliminación del antiguo hipervisor de respaldo.
8.º	ISP1 / WAN1 (NW-01)	Red	Enlace WAN primario. Sin Internet, la VPN cae, CloudFront se vuelve inaccesible y el ERP solo opera dentro de la LAN.
9.º	Respaldos en S3 AWS (D-04)	Datos	Última línea de defensa y origen de los datos consolidados en AWS RDS Multi-AZ. Sin estos respaldos, un desastre sería irrecuperable.
10.º	Cisco Catalyst 1000 (HW-05)	Hardware	Switch de distribución entre H1, H2 y H3; su falla desconecta a todos los hipervisores de la Sede Central.

Este inventario, estructurado conforme al Anexo B de (author?) [1], constituye el insumo directo del análisis de riesgos desarrollado en el siguiente capítulo. La valoración CIA asignada a

cada activo permite priorizar qué amenazas y vulnerabilidades deben evaluarse primero, evitando que el análisis de riesgos se realice sobre una base genérica desconectada de la infraestructura real de Franco's SAC.

CAPÍTULO 2

CE0322 - Análisis y Tratamiento de Riesgos de Seguridad

2.1 Metodología de análisis de riesgos

El análisis de riesgos de Franco's SAC se desarrolla conforme a la metodología cualitativa-cuantitativa de (author?) [1] y se mapea a los cinco dominios del (author?) [2] (*Identify, Protect, Detect, Respond, Recover*). Cada riesgo identificado parte de un activo del inventario desarrollado en el CE0321 y se evalúa combinando dos variables: la probabilidad de ocurrencia y el impacto sobre el negocio si la amenaza se materializa.

Tabla 3. Escalas de probabilidad e impacto del análisis de riesgos

Variable	Escala	Niveles (1 a 5)				
Probabilidad (P)	1–5	1 Muy baja	2 Baja	3 Media	4 Alta	5 Muy alta
Impacto (I)	1–5	1 Mínimo	2 Bajo	3 Medio	4 Alto	5 Crítico

El nivel de riesgo se calcula como $\text{Nivel} = P \times I$, con un rango posible de 1 a 25. La clasificación resultante se interpreta de la siguiente manera: **crítico** entre 20 y 25, **alto** entre 12 y 19, **medio** entre 6 y 11, y **bajo** entre 1 y 5. Para cada riesgo se define además una opción de tratamiento: **mitigar** (reducir P o I mediante controles), **transferir** (seguro o tercero), **aceptar** (riesgo residual documentado y comunicado a la Gerencia) o **evitar** (eliminar el activo o proceso asociado).

2.2 Matriz de riesgos identificados

El análisis identifica **18 riesgos** sobre la infraestructura de Franco's SAC. Cada riesgo combina una amenaza con una vulnerabilidad sobre uno o más activos del CE0321. Los riesgos de mayor nivel (crítico/alto) se concentran en el acceso no autorizado a BD, la denegación de servicio al ERP, la pérdida de respaldos y el compromiso de credenciales administrativas. Todos los riesgos tienen al menos un control asociado en el plan de tratamiento.

2.3 Mapeo a los dominios del NIST CSF y plan de tratamiento

Cada riesgo se vincula a una o más subcategorías del NIST CSF, ordenando los controles según su función: *Govern* (gobernanza de riesgo), *Protect* (controles preventivos), *Detect* (monitoreo y alertas), *Respond* (respuesta a incidentes) y *Recover* (recuperación). Esta vinculación es el puente entre el análisis de riesgos (CE0322) y las políticas de seguridad formales (CE0323).

CAPÍTULO 3

CE0323 - Políticas de Seguridad de la Información

3.1 Marco general de las políticas de seguridad

Las políticas de seguridad de Franco's SAC traducen en reglas formales los activos identificados en el CE0321 y los riesgos analizados en el CE0322. Cada política se redacta siguiendo una misma estructura –objetivo, alcance, responsable, procedimiento, indicadores de cumplimiento y referencia normativa– conforme a los lineamientos del Anexo A de (author?) [3].

Se definen seis políticas que, en conjunto, cubren los quince riesgos a mitigar identificados en el CE0322: control de acceso, gestión de contraseñas, respaldo y recuperación, gestión de parches, uso aceptable de los recursos de TI y respuesta a incidentes de seguridad.

Tabla 4. Políticas de seguridad y su relación con ISO 27001:2022 y el NIST CSF

Política	ISO 27001:2022	NIST CSF v2.0	Riesgos que mitiga
POL-01 – Control de acceso	A.9	PR.AC-1, PR.AC-3, PR.AC-4	R-02, R-05, R-13
POL-02 – Gestión de contraseñas	A.9.4.3	PR.AC-1, PR.AC-6	R-03, R-05
POL-03 – Respaldo y recuperación	A.12.3, A.17.1	PR.IP-4, RC.RP-1	R-01, R-07, R-09
POL-04 – Gestión de parches	A.12.6	PR.IP-12, DE.CM-8	R-01, R-04
POL-05 – Uso aceptable de TI	A.8, A.9.3	PR.AT-1	R-02, R-05, R-16
POL-06 – Respuesta a incidentes	A.16	RS.RP-1, RS.CO-2, RC.RP-1	R-01 a R-15

3.2 POL-01 — Política de control de acceso

Tabla 5. Política de control de acceso (POL-01)

Campo	Contenido
Objetivo	Garantizar que únicamente los usuarios autorizados accedan a los recursos de TI de Franco's SAC, conforme a su rol y aplicando el principio de mínimo privilegio.

Campo	Contenido
Alcance	Todos los sistemas: ERP (API Gateway y microservicios), Active Directory <code>francos.local</code> , bases de datos PostgreSQL, hipervisores ESXi, pfSense y AWS Cloud. Aplica a empleados, contratistas y al equipo de TI.
Responsable	Ruben Mark Salazar, con apoyo de Uziel Sauñe Fernandez.
Procedimiento	Se organizan grupos de Active Directory por área (producción, ventas, administración, TI) para un acceso granular. Cada usuario accede únicamente a los recursos necesarios para su función; los operarios de Local 1 y Local 3 acceden solo al módulo del ERP correspondiente. Cada microservicio dispone de su propio usuario de base de datos con permisos de lectura, inserción y actualización únicamente, sin privilegios de eliminación, alteración o creación de estructuras. Queda prohibido compartir credenciales entre usuarios. El ciclo de vida de las cuentas sigue un flujo definido: solicitud formal, alta en Active Directory, asignación de grupo y acceso activo; las bajas desactivan la cuenta dentro de las primeras 24 horas tras la desvinculación. El administrador de TI revisa trimestralmente todos los accesos activos y elimina los innecesarios. El acceso privilegiado por SSH a los hipervisores y a pfSense se restringe a la VLAN 10 de administración o a la VLAN 99 de gestión, con autenticación multifactor planificada para el segundo semestre.
Indicadores de cumplimiento	Porcentaje de cuentas revisadas en el último trimestre igual al 100%; número de cuentas compartidas detectadas igual a cero; tiempo de desactivación de cuenta al darse la baja menor o igual a 24 horas; accesos no autorizados detectados por Wazuh iguales a cero.
Referencia normativa	ISO 27001:2022 A.9 [3]; NIST CSF PR.AC-1, PR.AC-3, PR.AC-4 [2]; Ley N.º 29733, artículo 11 [4].

3.3 POL-02 — Política de gestión de contraseñas

Tabla 6. Política de gestión de contraseñas (POL-02)

Campo	Contenido
Objetivo	Asegurar que todas las contraseñas de los sistemas de Franco's SAC sean suficientemente robustas frente a ataques de fuerza bruta y diccionario.
Alcance	Todos los usuarios del dominio <code>francos.local</code> y las cuentas de servicio de los microservicios y las bases de datos.
Responsable	Ruben Mark Salazar en la dirección y aprobación; Joshua Josue Pedraza Perez en la aplicación técnica mediante directivas de grupo en Active Directory.

Campo	Contenido
Procedimiento	La directiva exige una longitud mínima de diez caracteres, con al menos una mayúscula, una minúscula, un número y un símbolo, sin admitir el nombre de usuario ni palabras de diccionario. La rotación es obligatoria cada 90 días, con un historial de las últimas doce contraseñas para evitar reutilización; en el primer ingreso el usuario debe cambiar su contraseña. Como protección ante ataques, la cuenta se bloquea tras cinco intentos fallidos durante 30 minutos, con una ventana de observación que se reinicia cada 30 minutos. Las cuentas de servicio –microservicios y bases de datos– usan contraseñas aleatorias de 20 o más caracteres, con rotación cada 180 días gestionada manualmente por el administrador de TI; las cuentas administrativas de ESXi y pfSense usan contraseñas de 16 o más caracteres conocidas solo por el equipo de TI.
Indicadores de cumplimiento	Porcentaje de usuarios con contraseña vencida igual a cero; número de cuentas bloqueadas por semana, como métrica de referencia con alerta si supera cinco por semana; porcentaje de cuentas de servicio con contraseña actualizada en los últimos 180 días igual al 100%.
Referencia normativa	ISO 27001:2022 A.9.4.3 [3]; NIST CSF PR.AC-1, PR.AC-6 [2]; NIST SP 800-63B, Guía de Identidad Digital [5].

3.4 POL-03 — Política de respaldo y recuperación

La política de respaldo y recuperación organiza los mecanismos de protección de datos en cinco niveles complementarios, desde la disponibilidad continua en AWS hasta los respaldos semanales de configuración de red.

Tabla 7. Niveles del procedimiento de respaldo de la política POL-03

Nivel	Tipo	Frecuencia	Hora	Destino	Retención	RPO
N1	AWS RDS Multi-AZ (intra-AWS)	Continua	24/7	VPC de recuperación, alimentada por N3	Permanente	≤ 24 h
N2	<i>Snapshot</i> ESXi de VM críticas	Diaria	23:00	VMFS6 local en H1–H3	7 días	24 h
N3	pg_dump hacia S3 AWS (3 BD)	Diaria	22:00	francos-db-backups	30 días	24 h
N4	Exportación OVF de VM hacia S3	Semanal	Domingo, 02:00	francos-vm-exports	4 semanas	7 días

Nivel	Tipo	Frecuencia	Hora	Destino	Retención	RPO
N5	Respaldo XML de pfSense (3 locales)	Semanal y ante cambios	–	S3 y servidor de monitoreo	30 días	7 días

Tabla 8. Objetivo, alcance y referencia normativa de la política POL-03

Campo	Contenido
Objetivo	Garantizar la disponibilidad y recuperabilidad de los datos críticos de Franco's SAC ante fallos, desastres o incidentes de seguridad, cumpliendo los objetivos de RPO y RTO definidos.
Alcance	Bases de datos PostgreSQL (<i>person-db</i> , <i>sales-invent-db</i> , <i>strategic-db</i>), configuraciones de pfSense en los tres locales, máquinas virtuales críticas de H1 a H3 e imágenes Docker en ECR.
Responsable	Administrador de bases de datos / Administrador de Sistemas, mediante ejecución automática por scripts <i>cron</i> .
Prueba de restauración	Obligatoria de forma trimestral: restauración del respaldo <i>pg_dump</i> en un ambiente aislado, verificación de integridad y documentación del resultado y la fecha. El RTO objetivo es menor o igual a 30 minutos para bases de datos y menor o igual a 4 horas para máquinas virtuales.
Indicadores de cumplimiento	Porcentaje de respaldos N3 completados exitosamente igual al 100% diario; respaldo <i>pg_dump</i> completado antes de las 23:00, medido por Wazuh; última prueba de restauración con una antigüedad menor o igual a 90 días; RTO alcanzado en la última prueba dentro del objetivo definido.
Referencia normativa	ISO 27001:2022 A.12.3 y A.17.1 [3]; NIST CSF PR.IP-4, RC.RP-1 [2]; NIST SP 800-34, Planificación de Contingencia [6].

3.5 POL-04 — Política de gestión de parches y actualizaciones

Tabla 9. Política de gestión de parches y actualizaciones (POL-04)

Campo	Contenido
Objetivo	Mantener todos los sistemas de Franco's SAC actualizados para mitigar vulnerabilidades conocidas, minimizando la ventana de exposición a ataques.
Alcance	Ubuntu Server 24.04 LTS, Docker Engine y las imágenes de contenedores, pfSense 2.7 CE, Samba AD-DC, PostgreSQL 15, NATS 2.x, NGINX con ModSecurity y Wazuh.

Campo	Contenido
Responsable	Ruben Mark Salazar en la direccion tecnica; Joshua Josue Pedraza Perez, Hilter Piero Lanche Cerro y Joel Joshep Rivera Matias en la ejecucion operativa.
Procedimiento	Las vulnerabilidades se clasifican por severidad CVSS: las críticas, con puntaje mayor o igual a 9.0, se parchean dentro de 72 horas, incluso en una ventana de emergencia fuera del horario laboral; las altas, entre 7.0 y 8.9, se parchean dentro de 15 días en la siguiente ventana de mantenimiento; las medias y bajas, por debajo de 7.0, se parchean en la ventana mensual. La ventana de mantenimiento programada es el primer sábado de cada mes, de 02:00 a 06:00 horas, con notificación previa a la Gerencia 72 horas antes y un plan de reversión basado en <i>snapshot</i> de ESXi antes de cada actualización crítica. El procedimiento de aplicación sigue cinco pasos: identificar las vulnerabilidades aplicables consultando fuentes oficiales, clasificarlas por severidad y componente afectado, tomar <i>snapshot</i> de las VM afectadas, aplicar el parche en la ventana correspondiente y verificar el funcionamiento mediante pruebas de salud, documentando la versión anterior, la nueva versión, la fecha y el responsable.
Indicadores de cumplimiento	Vulnerabilidades críticas pendientes por más de 72 horas iguales a cero; vulnerabilidades altas pendientes por más de 15 días iguales a cero; porcentaje de sistemas con versión documentada y actualizada igual al 100%; ventanas de mantenimiento ejecutadas según calendario iguales al 100%.
Referencia normativa	ISO 27001:2022 A.12.6, Gestión de Vulnerabilidades Técnicas [3]; NIST CSF PR.IP-12, DE.CM-8 [2]; CIS Benchmark para Ubuntu 24.04.

3.6 POL-05 — Política de uso aceptable de los recursos de TI

Tabla 10. Política de uso aceptable de los recursos de TI (POL-05)

Campo	Contenido
Objetivo	Definir el uso apropiado de los recursos tecnológicos de Franco's SAC para proteger la confidencialidad, integridad y disponibilidad de la información.
Alcance	Todos los empleados, operarios, contratistas y visitantes que utilicen recursos de TI de Franco's SAC: ERP, red WiFi, estaciones de trabajo y VPN.
Responsable	Jorge Andres Chavarri Centeno, en la comunicacion y enlace organizacional; Ruben Mark Salazar, en el control y monitoreo.

Campo	Contenido
Procedimiento	El uso permitido se limita a actividades laborales de Franco's SAC, con acceso al ERP únicamente mediante credenciales propias del dominio <code>francos.local</code> . Queda prohibido compartir credenciales, instalar software no autorizado en las estaciones del dominio, acceder a los sistemas desde dispositivos personales no autorizados, almacenar información confidencial fuera de los sistemas aprobados y eludir los controles de seguridad de VPN, <i>firewall</i> o VLAN. Los dispositivos personales no se conectan a la VLAN 20 sin autorización previa del administrador de TI y, de autorizarse, deben contar con antivirus activo y sistema operativo actualizado. Las violaciones se gradúan en tres niveles: una violación menor genera una advertencia formal documentada; una violación mayor implica suspensión de acceso y proceso disciplinario; una violación grave, como la divulgación de datos, puede implicar rescisión de contrato y acción legal conforme a la Ley N.º 29733.
Indicadores de cumplimiento	Porcentaje de empleados capacitados anualmente en la política igual al 100%; número de violaciones reportadas por trimestre, con tendencia decreciente esperada; accesos con credenciales compartidas detectados por Wazuh iguales a cero.
Referencia normativa	ISO 27001:2022 A.8 y A.9.3 [3]; NIST CSF PR.AT-1 [2]; Ley N.º 29733 [4].

3.7 POL-06 — Política de respuesta a incidentes de seguridad

La política de respuesta a incidentes clasifica cada evento en cuatro niveles de prioridad, cada uno con un tiempo de respuesta máximo definido.

Tabla 11. Clasificación de incidentes de la política POL-06

Prioridad	Criterio	Tiempo de respuesta	Ejemplos
P1 – Crítico	Impacto total en las operaciones; ERP inaccesible; datos comprometidos.	< 1 hora	<i>Ransomware</i> en bases de datos; caída total del ERP; filtración masiva de datos.
P2 – Alto	Impacto significativo; servicio degradado; riesgo inminente.	< 4 horas	Caída de pfSense; VPN caída; acceso no autorizado detectado.
P3 – Medio	Impacto parcial; servicio funcional con limitaciones.	< 24 horas	Alerta de Wazuh; respaldo fallido; alerta del WAF.

Prioridad	Criterio	Tiempo de respuesta	Ejemplos
P4 – Bajo	Sin impacto operativo; evento informativo.	< 72 horas	Intentos de inicio de sesión fallidos; parche pendiente.

El procedimiento de respuesta sigue seis fases. En la **deteccion**, Wazuh genera alertas automaticas, los usuarios o el soporte documental reportan al equipo tecnico y CloudWatch emite alertas en AWS. En la **clasificacion**, Ruben Mark Salazar y Uziel Sauñe Fernandez determinan la prioridad en un plazo menor o igual a 15 minutos. En la **contencion**, los incidentes P1 y P2 implican aislar la VLAN afectada en pfSense, revocar las credenciales comprometidas y desconectar la VM afectada, preservando evidencia en los registros de Wazuh, pfSense y PostgreSQL. En la **erradicacion**, se identifica la causa raiz, se elimina el malware o el acceso indebido y se aplica el parche correspondiente. En la **recuperacion**, los datos se restauran desde el respaldo `pg_dump` diario en S3 AWS o mediante conmutacion a RDS Multi-AZ y ECS Fargate, y las maquinas virtuales desde el *snapshot* diario de ESXi, verificando la integridad antes de reactivar el servicio. En el **post-incidente**, se completa un analisis de causa raiz dentro de cinco dias habiles, se documenta el incidente en Wazuh y se actualizan las politicas o controles si corresponde.

La cadena de escalamiento avanza del usuario o soporte documental al equipo tecnico en 15 minutos, de este a Ruben Mark Salazar en 30 minutos, y luego a Jorge Andres Chavarri Centeno de forma inmediata para incidentes P1 o dentro de dos horas para incidentes P2. En caso de brecha de datos personales, la notificacion a INDECOPI debe realizarse dentro de 72 horas conforme al articulo 26 del D.S. N.º 003-2013-JUS, y la notificacion a los afectados dentro de cinco dias habiles si existe riesgo para sus derechos.

Tabla 12. Indicadores y referencia normativa de la política POL-06

Campo	Contenido
Objetivo	Establecer el procedimiento formal para detectar, clasificar, contener, erradicar y recuperar la operación ante incidentes de seguridad, minimizando el impacto sobre Franco's SAC.
Alcance	Todos los sistemas de Franco's SAC –ERP, Active Directory, bases de datos, red e infraestructura– en los tres locales, ante cualquier evento que comprometa la confidencialidad, integridad o disponibilidad de los activos.

Campo	Contenido
Responsable	Ruben Mark Salazar en la coordinacion general; Uziel Sauñe Fernandez y el bloque tecnico en la respuesta tecnica; Jorge Andres Chavarri Centeno en la comunicacion y enlace organizacional.
Indicadores de cumplimiento	Tiempo medio de resolución de incidentes P1 menor o igual a 4 horas, de P2 menor o igual a 8 horas y de P3 menor o igual a 48 horas; porcentaje de incidentes con análisis de causa raíz completado en 5 días igual al 100%; incidentes recurrentes del mismo tipo iguales a cero tras la corrección; tiempo de notificación a la Gerencia en incidentes P1 menor o igual a 30 minutos.
Referencia normativa	ISO 27001:2022 A.16, Gestión de Incidentes [3]; NIST CSF RS.RP-1, RS.CO-2, RS.MI-1, RC.RP-1 [2]; Ley N.º 29733, artículo 26, y D.S. N.º 003-2013-JUS [7].

3.8 Cobertura de las políticas frente a los riesgos identificados

Las seis políticas, en conjunto, cubren los quince riesgos a mitigar identificados en el CE0322. POL-01 y POL-02 –control de acceso y gestión de contraseñas– mitigan los riesgos de acceso no autorizado (R-02, R-03 y R-05). POL-03 –respaldo y recuperación– cubre los riesgos de pérdida de datos (R-01, R-07 y R-09). POL-04 –gestión de parches– reduce la probabilidad de explotación de vulnerabilidades conocidas (R-01 y R-04). POL-05 y POL-06 cierran el ciclo, cubriendo la concientización del usuario final y la respuesta ante cualquier incidente que pudiera materializarse a pesar de los controles preventivos.

Esta cobertura completa constituye la base para asignar responsabilidades concretas, lo que se desarrolla en el siguiente capítulo mediante la matriz de roles y responsabilidades del sistema de gestión de seguridad de la información.

CAPÍTULO 4

CE0324 - Roles, Responsabilidades y Matriz RACI del SGSI

4.1 Estructura organizacional de seguridad de TI

La implementación efectiva de las políticas descritas en el CE0323 requiere una estructura de roles clara, donde cada persona o área conozca su nivel de responsabilidad. Para Franco's SAC se definen roles y responsables vinculados al SGSI, articulando dirección técnica, coordinación organizacional, seguridad, operación técnica, datos, documentación y evidencias.

Tabla 13. Estructura organizacional de seguridad de TI de Franco's SAC

Rol del SGSI	Persona / área	Nivel	Responsabilidad principal
Coordinación y Enlace Organizacional	Jorge Andres Chavarri Centeno, contacto de Franco's SAC	Estrategico	Aprobación de políticas, autorización de inversiones en seguridad, enlace con la organización y soporte de comunicación ante incidentes de datos (ISO 27001:2022 A.5.1, A.5.2).
Dirección del SGSI	Ruben Mark Salazar, Director del Proyecto ITI	Tactico	Definición y mantenimiento del SGSI, gestión de riesgos, supervisión de políticas, reporte al coordinador del proyecto y coordinación ante incidentes (ISO 27001:2022 A.5, A.6, A.16, A.18).
Administrador de Red e Infraestructura	Uziel Sauñe, Especialista ITI	Operativo	Gestión de pfSense, VPN, VLANs, Cisco Catalyst 1000, Dual-WAN, monitoreo con Wazuh y configuraciones de red (ISO 27001:2022 A.13, A.12.1).
Infraestructura, Virtualización y Operaciones	Joshua Pedraza, Hilter Lanche y Joel Rivera	Operativo	Gestión de hipervisores ESXi, máquinas virtuales, Docker, Active Directory, <i>snapshots</i> y actualizaciones de sistema operativo y aplicaciones (ISO 27001:2022 A.12, A.14).
Administrador de bases de datos	Evan Chacon	Operativo	Gestión de PostgreSQL 15, respaldos <i>pg_dump</i> diarios hacia S3 AWS, usuarios y permisos de base de datos, e integridad de los datos (ISO 27001:2022 A.10, A.12.3).
Soporte documental, evidencias y usuarios finales	Pamela Vallejos, Veronica Vergara y empleados de Franco's SAC	Usuario	Uso del ERP conforme a la POL-05, reporte de incidentes, cumplimiento de la política de contraseñas y no compartir credenciales (ISO 27001:2022 A.7, A.9.3).

La estructura sigue una línea de reporte directa: Uziel Sauñe Fernandez, el bloque de infraestructura/virtualización

y Evan Chacon reportan a Ruben Mark Salazar; Ruben Mark Salazar rinde cuentas ante la estructura de direccion del proyecto; y los usuarios finales o el soporte documental reportan cualquier incidente al equipo tecnico correspondiente segun el sistema afectado.

4.2 Matriz RACI de procesos de seguridad

La matriz RACI asigna de forma explícita quién ejecuta (R), quién rinde cuentas (A), a quién se consulta (C) y a quién se informa (I) en cada proceso de seguridad. Cubre **13 procesos** de seguridad y los **6 roles** del SGSI definidos en CE0324: CISO, Jefe de TI, Administrador de Sistemas, Analista de Seguridad, Oficial de Datos y Gerencia General. Esta matriz evita la ambigüedad de responsabilidades en la respuesta a incidentes y la gestión de accesos.

4.3 Responsabilidades operativas por frecuencia

Además de la matriz RACI, las responsabilidades se organizan por frecuencia de ejecución, lo que facilita su seguimiento operativo diario, semanal, mensual y trimestral.

Tabla 14. Responsabilidades operativas de seguridad por frecuencia

Frecuencia	CISO	Admin. Red	Admin. Sistemas / DBA	Usuario final
Diaria	Revisar alertas de Wazuh, registros de acceso de AD y el estado de los incidentes abiertos.	Verificar el estado de las VPN L1–L2, L2–L3 y L2–AWS, revisar los registros del WAF y confirmar que el Dual-WAN esté activo.	Confirmar el respaldo <code>pg_dump</code> del día anterior, insumo de AWS RDS Multi-AZ, y revisar las pruebas de salud de Docker.	Usar el ERP con credenciales propias y reportar cualquier anomalía de inmediato al administrador de TI.
Semanal	Revisar el informe de respaldos en S3, las vulnerabilidades nuevas publicadas y actualizar el registro de riesgos si corresponde.	Revisar los registros completos del <i>firewall</i> , verificar los respaldos XML de pfSense en los tres locales y revisar el muestreo SNMP del Cisco Catalyst 1000.	Confirmar la llegada del OVF del domingo a S3, revisar el estado de los <i>snapshots</i> de ESXi y los registros de auditoría de PostgreSQL.	Verificar que la contraseña no esté próxima a vencer y reportar cualquier incidente de la semana.
Mensual	Aplicar parches en la ventana de mantenimiento, revisar los indicadores de seguridad y elaborar el reporte mensual a la Gerencia.	Aplicar parches de pfSense y del Cisco IOS, optimizar las reglas de las listas de control de acceso y revisar el <i>trunking</i> 802.1Q y las VLANs activas.	Aplicar parches de Ubuntu, Docker y PostgreSQL, revisar roles y permisos en todas las bases de datos y revisar la capacidad de VMFS6 y S3.	Completar el módulo de capacitación en seguridad y cumplir la política POL-05.
Trimestral	Revisar y actualizar las políticas del SGSI, revisar los accesos y usuarios de AD, y elaborar el informe ejecutivo para la Gerencia.	Auditar la seguridad de la red, revisar los registros de VPN de los últimos tres meses y probar el <i>failover</i> del Dual-WAN.	Probar la restauración de respaldos en un ambiente aislado, verificar el OVF en S3 y revisar los índices y el rendimiento de las bases de datos.	Recibir la capacitación formal en seguridad de la información definida en la política POL-05.

4.4 Vinculación de los roles con los controles de ISO 27001:2022

Cada rol del SGSI se vincula con un subconjunto específico de controles del Anexo A de (author?) [3], lo que permite auditar posteriormente si cada control tiene un responsable claramente identificado.

Tabla 15. Vinculación de roles con los controles de ISO 27001:2022

Rol	Controles principales	Descripción del control
Gerencia General	A.5.1, A.5.2, A.5.4	Políticas de seguridad aprobadas por la dirección; responsabilidad de la dirección; roles y responsabilidades de seguridad.
CISO	A.5.1, A.6.1, A.16.1, A.18.1, A.18.2	Gestión del SGSI; definición de roles; coordinación de incidentes; cumplimiento legal de la Ley N.º 29733; revisiones independientes.
Administrador de Red e Infraestructura	A.8.21, A.8.22, A.8.23, A.13.1, A.13.2	Segmentación de redes mediante VLANs; filtrado de tráfico con ACL en pfSense; separación de entornos; transferencia segura de información por VPN.
Administrador de Sistemas	A.8.8, A.8.19, A.12.1, A.12.4, A.12.6	Gestión de vulnerabilidades técnicas; instalación de software; operaciones seguras; registro de eventos; mantenimiento.
Administrador de bases de datos	A.8.3, A.8.10, A.10.1, A.12.3	Restricción de acceso a la información con mínimo privilegio; eliminación segura de información; controles criptográficos; copias de seguridad.
Usuario final	A.6.3, A.7.1, A.7.2, A.9.3	Concientización en seguridad; responsabilidades del empleado; uso aceptable de activos; responsabilidades de autenticación.

La matriz RACI y la vinculación normativa permiten concluir que cada proceso de seguridad de Franco's SAC tiene exactamente un responsable que rinde cuentas, y que cada rol operativo conoce con precisión qué controles del Anexo A de (author?) [3] debe sostener en su gestión diaria. Esta claridad de responsabilidades constituye el último elemento técnico antes del cierre documental y ético del Entregable 2, desarrollado en el siguiente capítulo.

CAPÍTULO 5

CE0325 - Calidad Documental y Ética Profesional del Entregable 2

5.1 Propósito del cierre documental y ético

El presente capítulo cierra el Entregable 2 desde dos dimensiones complementarias: la calidad documental del conjunto CE0321–CE0324 y la responsabilidad ética aplicada a la planificación de seguridad de la información de Franco's SAC. A diferencia de los capítulos anteriores, este no incorpora nuevos activos, riesgos, políticas ni roles. Su función es verificar que lo ya desarrollado mantenga coherencia interna, trazabilidad y una postura profesional responsable frente al manejo de información sensible.

La gestión de la seguridad de la información involucra decisiones que afectan datos personales, privacidad y continuidad operativa. Por ello, la dimensión ética se aborda desde el **(author?)** [8], considerando principios como el bienestar social, la prevención del daño, la honestidad profesional, la equidad, la privacidad, la confidencialidad y el diseño de sistemas seguros.

5.2 Revisión de coherencia del Entregable 2

La coherencia del SGSI de Franco's SAC requiere que cada sección del Entregable 2 sea insumo directo de la siguiente. La revisión verifica la trazabilidad entre los cinco criterios del entregable: activos, riesgos, políticas, roles y ética.

Tabla 16. Revisión de coherencia del Entregable 2 (CE0321–CE0324)

#	Punto de coherencia verificado	CE0321	CE0322	CE0323	CE0324	Estado
C-01	Cada riesgo referencia el activo afectado del inventario del CE0321.	D-01 a P-04	R-01 a R-18	–	–	Coherente
C-02	Cada política del CE0323 mitiga riesgos identificados en el CE0322.	–	R-01 a R-18	POL-01 a 06	–	Coherente
C-03	Cada política tiene un único <i>Accountable</i> en la matriz RACI del CE0324.	–	–	POL-01 a 06	RACI – A	Coherente
C-04	Los activos críticos <i>person-db</i> y <i>sales-invent-db</i> tienen riesgos específicos y políticas dedicadas.	D-01, D-02 (valor 5)	R-01, R-02, R-04	POL-01, POL-03	DBA <i>Accountable</i>	Coherente
C-05	Los riesgos aceptados (R-12, R-17, R-18) están justificados y no generan políticas operativas adicionales.	S-02, HW-01/02	R-12, R-17, R-18: Aceptar	Sin política	Sin RACI específico	Coherente
C-06	La persona asignada como CISO (Ruben Mark Salazar) aparece consistentemente en la portada, la matriz RACI y la declaración.	–	–	–	A en 10 de 13 procesos	Coherente

#	Punto de coherencia verificado	CE0321	CE0322	CE0323	CE0324	Estado
C-07	ISO 27001 y el NIST CSF se referencian de forma consistente en los cuatro capítulos.	ISO 27005	NIST CSF v2.0	ISO 27001 A.9–A.16	ISO 27001 A.5–A.18	Coherente
C-08	La Ley N.º 29733 aparece en activos, riesgos, políticas y roles de forma consistente.	D-01 – Ley 29733	R-02 – Ley 29733	POL-05, POL-06	CISO notifica	Coherente

Los ocho puntos de coherencia verificados confirman la trazabilidad completa del Entregable 2: los activos conducen a los riesgos, los riesgos conducen a las políticas, las políticas conducen a los roles, y el conjunto se sostiene sobre los mismos marcos normativos –ISO 27001:2022, ISO 27005:2022, el NIST CSF v2.0 y la Ley N.º 29733– sin contradicciones entre capítulos.

5.3 Aplicación del Código de Ética de la ACM

La planificación de la seguridad de la información de Franco's SAC se revisa frente a los principios del (author?) [8], en un ejercicio análogo al realizado para el diseño de red en el CE0316 del Entregable 1.

Tabla 17. Aplicación del Código de Ética de la ACM a la planificación de seguridad

Principio ACM	Aplicación concreta en el SGSI de Franco's SAC	Evidencia en el Entregable 2
1.1 – Contribuir al bienestar de la sociedad	Las seis políticas de seguridad protegen los datos de entre 30 y 40 trabajadores y de sus clientes. Un SGSI robusto garantiza la continuidad del negocio y la estabilidad económica de los empleados.	CE0321 – 28 activos; CE0323 – POL-01, POL-02.
1.2 – Evitar causar daño	El análisis de riesgos identifica sistemáticamente los daños potenciales antes de que ocurran. Las políticas implementan controles preventivos. Los riesgos aceptados se documentan con justificación y se comunican a la Gerencia para una decisión informada.	CE0322 – 18 riesgos; CE0323; CE0324 – RACI.
1.3 – Ser honesto y confiable	Los riesgos R-12, R-17 y R-18 se aceptan de forma transparente y documentada, reconociendo que están fuera del control total del proyecto. No se afirma que el sistema sea completamente seguro; se comunica el riesgo residual a la Gerencia.	CE0322 – R-12, R-17, R-18; CE0324 – Gerencia <i>Informed</i> .
1.4 – Ser justo y no discriminar	La POL-01 garantiza acceso equitativo al ERP para todos los trabajadores según su rol, sin distinción por sede. Los RODC de Local 1 y Local 3 aseguran que los operarios de planta cuenten con el mismo nivel de autenticación que el personal de la Sede Central.	CE0323 – POL-01; CE0324 – Usuario final.
1.6 – Respetar la privacidad	<i>person-db</i> contiene datos personales regulados por la Ley N.º 29733. Se implementan controles específicos: VLAN aislada, mínimo privilegio en PostgreSQL, cifrado en tránsito y respaldo cifrado en S3.	CE0321 – D-01; CE0322 – R-02; CE0323 – POL-05, POL-06.

Principio ACM	Aplicación concreta en el SGSI de Franco's SAC	Evidencia en el Entregable 2
1.7 – Honrar la confidencialidad	La información de riesgos de Franco's SAC –vulnerabilidades identificadas, activos críticos, configuraciones– se trata con estricta confidencialidad y se clasifica como de uso académico restringido.	Clasificación del documento; Acta de Conformidad.
2.5 – Evaluación exhaustiva de los impactos	El inventario cubre 28 activos en seis categorías; el análisis de riesgos evalúa 18 riesgos con metodología cuantitativa. Ningún riesgo se minimiza por conveniencia: los ocho riesgos de nivel alto están documentados con sus controles.	CE0321 – 28 activos; CE0322 – 18 riesgos.
2.9 – Diseñar sistemas seguros	Las políticas de seguridad definen controles desde el diseño del SGSI, no como un parche posterior. La POL-04 y la POL-06 garantizan que el sistema mantenga su postura de seguridad en el tiempo.	CE0323 – POL-01 a POL-06; CE0324 – RACI operativo.

5.4 Impacto social, legal y responsabilidad profesional

El SGSI diseñado para Franco's SAC genera implicaciones más allá del ámbito técnico, particularmente en el tratamiento de datos personales y en la continuidad operativa de una organización con entre 30 y 40 trabajadores.

Tabla 18. Impacto social, legal y responsabilidad profesional del Entregable 2

Dimensión	Análisis	Control implementado
Ley N.º 29733 – Protección de Datos Personales	<i>person-db</i> contiene datos personales de empleados, clientes y proveedores. La ley exige consentimiento informado, medidas de seguridad técnicas, no cesión a terceros sin autorización y notificación de brechas dentro de 72 horas al INDECOPI.	VLAN aislada; mínimo privilegio en la base de datos; VPN cifrada; POL-06 con notificación a INDECOPI dentro de 72 horas; respaldo en una región autorizada de AWS.
D.S. N.º 003-2013-JUS – Reglamento de la Ley N.º 29733	Obliga al responsable del banco de datos a implementar medidas de seguridad físicas, técnicas y organizativas proporcionales al riesgo. Franco's SAC es responsable de los datos almacenados.	El CE0321 al CE0324 constituyen el marco de medidas organizativas; las medidas técnicas se desarrollaron en el Entregable 1 (CE0313 a CE0315).

Dimensión	Análisis	Control implementado
Impacto social en los empleados	Un incidente de seguridad que paralice el ERP impacta directamente a entre 30 y 40 trabajadores: sin registro de ventas, sin control de inventario y sin remuneraciones a tiempo.	Disponibilidad objetivo del 99% en horario laboral; RTO y RPO definidos; RODC garantiza autenticación local sin VPN; conmutación a AWS ante falla de la Sede Central.
Ley N.º 30096 – Delitos Informáticos [9]	El acceso no autorizado a sistemas informáticos y la interceptación de datos son delitos tipificados. El SGSI reduce la probabilidad de ser víctima y documenta los controles de debida diligencia del responsable.	WAF ModSecurity; VPN cifrada; ACL en pfSense; auditoría con Wazuh; POL-06 de respuesta a incidentes.
Responsabilidad profesional del equipo ITI	El diseño del SGSI genera obligaciones éticas: documentar los riesgos con honestidad, no ocultar vulnerabilidades a la Gerencia y recomendar controles proporcionales al riesgo y al presupuesto disponible.	R-12, R-17 y R-18 documentados y aceptados con justificación; riesgos comunicados a la Gerencia mediante la matriz RACI.

5.5 Declaración de calidad documental y ética del Entregable 2

A partir de la revisión realizada en los bloques anteriores, se declara que el Entregable 2 mantiene una estructura documental coherente y una orientación ética adecuada para el alcance académico del proyecto. Esta declaración no representa una certificación externa de seguridad ni una auditoría formal del SGSI, sino una validación interna del documento respecto a claridad técnica, trazabilidad y responsabilidad profesional.

El conjunto CE0321–CE0325 se elaboró como una línea continua: primero se identifican y valoran los activos, luego se analizan los riesgos que los amenazan, después se definen las políticas que los mitigan, se asignan roles y responsabilidades concretas, y finalmente se revisa la calidad documental y ética del trabajo completo.

Tabla 19. Declaración de calidad documental y ética del Entregable 2

Eje declarado	Declaración	Evidencia dentro del entregable
Calidad documental	El Entregable 2 está compuesto por cinco secciones que cubren la totalidad de los criterios de la rúbrica CE032, con terminología técnica alineada a ISO 27005:2022, ISO 27001:2022 y el NIST CSF v2.0.	CE0321–CE0325; ocho puntos de coherencia verificados en la sección anterior.
Código de Ética ACM	Los ocho principios revisados del (author?) [8] se aplicaron explícitamente en el diseño del SGSI, priorizando la protección de datos personales y documentando con transparencia los riesgos aceptados.	Sección de aplicación del Código de Ética ACM de este capítulo.
Marco legal peruano	El SGSI incorpora los requisitos de la Ley N.º 29733 y su reglamento, especialmente en la protección de <i>person-db</i> y en el procedimiento de notificación ante brechas de datos.	CE0323 – POL-05, POL-06; sección de impacto social y legal de este capítulo.
Transparencia	Los riesgos R-12, R-17 y R-18 se aceptaron de forma documentada y comunicada a la Gerencia, reconociendo los límites del control del proyecto sobre la infraestructura física del laboratorio de la UPeU.	CE0322 – R-12, R-17, R-18; CE0324 – matriz RACI.

Con base en esta revisión, se deja constancia de que el Entregable 2 ha sido elaborado con una intención técnica y ética clara. El documento no se limita a enumerar controles de seguridad, sino que explica por qué cada control responde a un riesgo identificado sobre un activo concreto de Franco's SAC, y reconoce honestamente los riesgos que quedan fuera del control directo del proyecto.

5.6 Cierre del Entregable 2

El presente bloque cierra el segundo Entregable correspondiente a la planificación de seguridad de la información para Franco's SAC. Tras revisar los capítulos CE0321 a CE0325, se evidencia que el documento desarrolla una línea técnica continua: identifica los activos, analiza los riesgos que los amenazan, define las políticas que los mitigan, asigna responsabilidades concretas y cierra con una revisión documental y ética.

Tabla 20. Cierre del Entregable 2 según ejes documentales

Eje del entregable	Resultado alcanzado	Estado
Identificación de activos	Se identificaron y valoraron 28 activos en seis categorías mediante el modelo CIA, conforme al Anexo B de ISO 27005:2022.	Cubierto
Análisis de riesgos	Se analizaron 18 riesgos mediante la metodología Probabilidad × Impacto, mapeados a los cinco dominios del NIST CSF v2.0.	Cubierto
Políticas de seguridad	Se definieron seis políticas formales que cubren los quince riesgos a mitigar, alineadas al Anexo A de ISO 27001:2022.	Cubierto
Roles y responsabilidades	Se establecieron seis roles del SGSI, una matriz RACI de trece procesos y responsabilidades operativas por frecuencia.	Cubierto
Calidad documental y ética	Se verificó la coherencia entre los cinco criterios, se aplicaron los principios del Código de Ética ACM y se analizó el impacto legal y social del SGSI.	Cubierto

El resultado es un sistema de gestión de seguridad de la información organizado, trazable y defendible, que complementa el diseño de red del Entregable 1 y constituye la base de seguridad sobre la cual se sostiene el diseño del centro de datos desarrollado en el Entregable 3.

CAPÍTULO A

Anexo A — Inventario de Activos Primarios — Datos e Información

Los activos de datos e información constituyen el núcleo del ERP de Franco's SAC. Incluyen las bases de datos operativas, los respaldos generados a partir de ellas y las configuraciones que permiten reconstruir la infraestructura ante un incidente. Estos activos concentran los valores más altos del inventario porque su pérdida o corrupción afecta directamente la continuidad del negocio y, en el caso de los datos personales, genera responsabilidad legal conforme a la Ley N.º 29733.

Tabla 21. Inventario de activos primarios — Datos e información

Código	Activo	Descripción	Propietario	C / I / A	Valor y clasificación
D-01	person-db	Base de datos PostgreSQL con datos de empleados, clientes y proveedores de Franco's SAC: nombres, DNI, contactos y roles. Sujeta a la Ley N.º 29733.	Gerencia General	5 / 5 / 4	5 – Crítico
D-02	sales-invent-db	Base de datos de ventas e inventario: órdenes, productos, stock, precios y clientes. Núcleo del ERP operativo.	Gerencia Comercial	4 / 5 / 5	5 – Crítico
D-03	strategic-db	Base de datos de KPI, reportes de inteligencia de negocio y métricas estratégicas.	Gerencia General	4 / 3 / 3	4 – Alto
D-04	RespalDOS en S3 AWS	Copias pg_dump diarias de las tres bases de datos y exportaciones OVF semanales, almacenadas en francos-db-backups/ y francos-vm-exports/, con retención de 30 días.	Equipo TI	5 / 4 / 4	5 – Crítico
D-05	Configuración pfSense (XML)	Respaldo XML de las reglas de firewall, túneles VPN, DHCP y NAT de pfSense-BORDE, pfSense-L1 y pfSense-L3.	Equipo TI	5 / 5 / 3	5 – Crítico
D-06	Imágenes Docker (ECR)	Imágenes Docker de los microservicios (gateway, autenticación, personas, ventas, estratégico) almacenadas en AWS ECR.	Equipo TI / Desarrollo	3 / 4 / 3	4 – Alto

CAPÍTULO B

Anexo B — Inventario de Activos Primarios — Servicios y Procesos de Negocio

Los servicios y procesos de negocio representan la operación visible de Franco's SAC: el sistema ERP, la autenticación corporativa, la conectividad entre sedes, la resolución de nombres, el monitoreo y la interfaz de usuario. A diferencia de los activos de datos, su pérdida no implica necesariamente pérdida de información, pero sí interrupción del proceso de negocio asociado.

Tabla 22. Inventario de activos primarios — Servicios y procesos de negocio

Código	Activo	Descripción	Propietario	C / I / A	Valor y clasificación
S-01	ERP Franco's SAC (API Gateway + microservicios)	Sistema ERP completo: API Gateway en NestJS, broker NATS y los microservicios de autenticación, personas, ventas/inventario y estratégico. Proceso de negocio principal.	Gerencia General	4 / 5 / 5	5 – Crítico
S-02	Active Directory (DC1 único + RODC L1/L3)	Servicio de autenticación corporativa francos.local . El DC1 (H2) no cuenta con réplica on-premises –riesgo aceptado–; los RODC de Local 1 y Local 3 cubren autenticación local en caché.	Equipo TI	4 / 5 / 5	5 – Crítico
S-03	Conectividad VPN (L1-L2, L2-L3, L2-AWS)	Túneles IPSec IKEv2 con AES-256-GCM que interconectan los tres locales y AWS. Sin VPN activa, Local 1 y Local 3 no acceden al ERP ni sincronizan datos.	Equipo TI	3 / 4 / 5	5 – Crítico
S-04	DNS francos.local	Resolución de nombres internos para el controlador de dominio, el API Gateway y los microservicios. Sin DNS, el ERP y la autenticación dejan de operar.	Equipo TI	2 / 4 / 5	5 – Crítico
S-05	Monitoreo (Wazuh + CloudWatch)	Plataforma de observabilidad y SIEM centralizada que cubre los tres locales y AWS, con alertas ante caídas de servicio y anomalías.	Equipo TI	2 / 3 / 3	3 – Importante
S-06	Frontend Angular (CloudFront + S3 AWS)	Interfaz del ERP servida desde CloudFront y alojamiento estático en S3. Punto de acceso de todos los usuarios al sistema.	Equipo de Desarrollo / TI	2 / 4 / 4	4 – Alto

CAPÍTULO C

Anexo C — Inventario de Activos Secundarios — Software, Hardware, Red y Personas

Los activos secundarios sostienen técnica y humanamente a los activos primarios descritos en las secciones anteriores. Se agrupan en cuatro subcategorías –software de infraestructura, hardware, infraestructura de red y personas– siguiendo la misma lógica de valoración CIA, salvo en el caso de las personas, donde la criticidad se asocia al conocimiento que poseen sobre la operación de la infraestructura.

C.0.1 Software de infraestructura

Tabla 23. Inventario de activos secundarios — Software de infraestructura

Código	Software	C / I / A	Valor y clasificación
SW-01	pfSense 2.7 CE – firewall, router y concentrador VPN	5 / 5 / 5	5 – Crítico
SW-02	VMware ESXi 8.0 Update 3 – plataforma de virtualización	3 / 5 / 5	5 – Crítico
SW-03	Samba AD-DC 4.x – directorio activo	5 / 5 / 5	5 – Crítico
SW-04	PostgreSQL 15 – motor de bases de datos	4 / 5 / 4	5 – Crítico
SW-05	NATS 2.x con JetStream – message broker	2 / 4 / 5	5 – Crítico
SW-06	Docker Engine – plataforma de contenedores	2 / 4 / 4	4 – Alto
SW-07	NGINX con ModSecurity v3 – WAF	3 / 4 / 4	4 – Alto
SW-08	Wazuh 4.x – monitoreo y SIEM	2 / 3 / 3	3 – Importante

C.0.2 Hardware

Tabla 24. Inventario de activos secundarios — Hardware

Código	Activo y ubicación	C / I / A	Valor y clasificación
HW-01	ESXi H1 – Dell Precision 7920 (6 núcleos Xeon Bronze, 31.65 GB RAM, 348 GB). Sede Central, Local 2.	3 / 4 / 5	5 – Crítico

Código	Activo y ubicación	C / I / A	Valor y clasificación
HW-02	ESXi H2 y H3 – hipervisores de Servicios y Backend. Sede Central, Local 2.	3 / 4 / 5	5 – Crítico
HW-03	ESXi H4 – hipervisor de Local 1.	2 / 3 / 4	4 – Alto
HW-04	ESXi H5 – hipervisor de Local 3.	2 / 3 / 4	4 – Alto
HW-05	Cisco Catalyst 1000 – switch de distribución de la Sede Central.	2 / 4 / 5	5 – Crítico
HW-06	FortiGate 40F – gateway de respaldo ISP2/WAN2.	2 / 3 / 3	3 – Importante
HW-07	AP WiFi FrancosCorp – acceso inalámbrico VLAN 20.	2 / 2 / 2	2 – Normal

C.0.3 Infraestructura de red y personas

Tabla 25. Inventario de activos secundarios — Infraestructura de red

Código	Activo	C / I / A	Valor y clasificación
NW-01	ISP1 / WAN1 – enlace primario de Internet y VPN (Cisco Router del laboratorio).	2 / 3 / 5	5 – Crítico
NW-02	ISP2 / WAN2 – enlace secundario con conmutación automática (FortiGate 40F).	2 / 3 / 4	4 – Alto
NW-03	Túnel VPN L1–L2 – conectividad entre Local 1 y Sede Central.	3 / 4 / 4	4 – Alto
NW-04	Túnel VPN L2–L3 – conectividad entre Sede Central y Local 3.	3 / 4 / 4	4 – Alto
NW-05	Túnel VPN L2–AWS – conectividad privada hacia AWS para respaldos e imágenes Docker.	3 / 3 / 3	3 – Importante

Tabla 26. Inventario de activos secundarios — Personas

Código	Activo	Conocimiento crítico que posee	Clasificación
P-01	Equipo TI del proyecto	Configuración de pfSense, ESXi, Active Directory, VPN y respaldos. Sin este conocimiento, la recuperación ante fallos es inviable.	Crítico
P-02	Gerencia de Franco's SAC	Autorización de cambios en sistemas críticos y acceso a información financiera.	Alto
P-03	Personal de ventas y administración (Local 2)	Uso del ERP para registro de ventas, facturación y reportes.	Importante
P-04	Operarios de producción (Local 1, Local 3)	Registro de producción y acceso a inventario a través del ERP.	Normal

CAPÍTULO D

Anexo D — Matriz Completa de Riesgos Identificados

El análisis identifica dieciocho riesgos sobre la infraestructura de Franco's SAC. Cada riesgo combina una amenaza –el evento que podría ocurrir– con una vulnerabilidad –la condición que permite que la amenaza se materialice– sobre uno o más activos del inventario del CE0321.

Tabla 27. Matriz de riesgos identificados sobre la infraestructura de Franco's SAC

ID	Amenaza	Vulnerabilidad	Activo afectado	P / I / Nivel	Tratamiento
R-01	Ransomware cifra las bases de datos PostgreSQL	Acceso lateral si un contenedor Docker es comprometido; sin aislamiento total de la VLAN 50	D-01, D-02	3 / 5 / 15	Mitigar
R-02	Acceso no autorizado a datos personales	Credenciales de base de datos débiles o compartidas; sin auditoría de acceso activa	D-01, P-01–P-04	3 / 5 / 15	Mitigar
R-03	Fuerza bruta / <i>credential stuffing</i> al API Gateway	Endpoint TCP 443 expuesto a Internet; <i>rate limiting</i> solo en el WAF (100 req/s)	S-01	4 / 4 / 16	Mitigar
R-04	Inyección SQL a través de microservicios	Validación insuficiente de entradas si un microservicio no usa el ORM correctamente	D-01, D-02, D-03	3 / 5 / 15	Mitigar
R-05	Compromiso de credenciales de AD por <i>phishing</i>	Usuarios sin autenticación multifactor; política de contraseñas sin verificación en tiempo real	S-02, SW-03	3 / 5 / 15	Mitigar
R-06	Caída del ISP1 / WAN1 primario	Enlace WAN primario sin garantía de disponibilidad del proveedor	NW-01, S-01, S-03	3 / 4 / 12	Mitigar

ID	Amenaza	Vulnerabilidad	Activo afectado	P / I / Nivel	Tratamiento
R-07	Pérdida o fallo del respaldo diario pg_dump hacia S3	Dependencia del túnel VPN L2–AWS; sin alerta automática si el respaldo falla	D-04	3 / 4 / 12	Mitigar
R-08	Error de configuración en pfSense	Sin proceso formal de gestión de cambios; cambios sin respaldo previo	SW-01, D-05	3 / 4 / 12	Mitigar
R-09	Falla del hipervisor H3 (<i>backend</i> : microservicios y bases de datos primarias)	Todos los microservicios y bases de datos primarias en un único host físico	S-01, D-01–D-03	2 / 5 / 10	Mitigar
R-10	Caída de pfSense-BORDE (concentrador VPN y <i>firewall</i> principal)	Punto único de falla de toda la conectividad interlocal y el filtrado de tráfico	SW-01, S-03, S-01	2 / 5 / 10	Mitigar
R-11	Interceptación de tráfico interlocal durante una falla temporal de la VPN	Ventana breve sin cifrado durante la reconexión <i>Dead Peer Detection</i> del túnel	D-01, D-02, S-03	2 / 5 / 10	Mitigar
R-12	Caída del DNS francos.local (DC1 sin failover)	Sin un segundo controlador de dominio activo, el DNS deja de responder y el ERP falla	S-04, S-02, S-01	2 / 5 / 10	Aceptar
R-13	Exfiltración de datos mediante un token JWT robado	Token de larga duración interceptado permite acceso ilegítimo al ERP	D-01, D-02, S-01	2 / 5 / 10	Mitigar

ID	Amenaza	Vulnerabilidad	Activo afectado	P / I / Nivel	Tratamiento
R-14	Ataque de denegación de servicio distribuido al API Gateway / CloudFront	Saturación del <i>endpoint</i> HTTPS; WAF limitado a 100 req/s por IP	S-01, S-06	2 / 4 / 8	Mitigar
R-15	Inyección de mensajes falsos en NATS	NATS sin autenticación NKeys explícita; acceso disponible desde la VLAN 40 interna	SW-05, S-01	2 / 4 / 8	Mitigar
R-16	Pérdida de conocimiento crítico del equipo TI	Conocimiento no documentado sobre la configuración de la infraestructura	P-01	3 / 3 / 9	Mitigar
R-17	Acceso físico no autorizado a los hipervisores del laboratorio	El control de acceso físico depende de las políticas de UPeU, no del proyecto	HW-01, HW-02	2 / 5 / 10	Aceptar
R-18	Interrupción prolongada de energía en el laboratorio	Sin UPS ni grupo electrógeno bajo control del proyecto	HW-01, HW-02, HW-05	2 / 5 / 10	Aceptar

De los dieciocho riesgos identificados, ocho alcanzan nivel alto ($P \times I$ entre 12 y 16) y diez alcanzan nivel medio ($P \times I$ entre 8 y 10). Ningún riesgo alcanza nivel crítico, resultado que se explica por los controles de redundancia ya implementados en el Entregable 1: Dual-WAN, CARP en alta disponibilidad, respaldo y recuperación ante desastres consolidados en AWS, y un WAF en la zona desmilitarizada.

D.1 Mapa de calor de probabilidad e impacto

El mapa de calor permite visualizar de forma conjunta la distribución de los dieciocho riesgos según su probabilidad y su impacto, facilitando la identificación de las combinaciones que concentran mayor exposición.

P \ I	1 Mínimo	2 Bajo	3 Medio	4 Alto	5 Crítico
5 Muy alta	5	10	15	20	25
4 Alta	4	8	12	16 – R-03	20
3 Media	3	6	9 – R-16	12 – R-06, R-07, R-08	15 – R-01, R-02, R-04, R-05
2 Baja	2	4	6	8 – R-14, R-15	10 – R-09, R-10, R-11, R-12, R-13, R-17, R-18
1 Muy baja	1	2	3	4	5

Ningún riesgo se ubica en la zona crítica del mapa de calor ($P \times I$ mayor o igual a 20), lo que confirma que los controles de redundancia descritos en el CE0314 –Dual-WAN, CARP en alta disponibilidad, respaldo y recuperación ante desastres en AWS y WAF– ya reducen la probabilidad o el impacto de las amenazas más severas antes de aplicar los controles adicionales que se detallan en el siguiente capítulo.

CAPÍTULO E

Anexo E — Mapeo al NIST CSF y Plan de Tratamiento de Riesgos

Cada riesgo se vincula a uno o más subcategorías del **(author?)** [2], lo que permite ordenar los controles según su función: proteger, detectar, responder o recuperar. Esta vinculación es el puente entre el análisis de riesgos y las políticas de seguridad formales que se desarrollan en el CE0323.

Tabla 28. Mapeo de riesgos a NIST CSF v2.0 y control implementado

ID	Riesgo (resumen)	Nivel	NIST CSF	Control implementado o acción	Tratamiento
R-01	Ransomware en bases de datos PostgreSQL	Alto	PR.DS-1, RC.RP	VLAN 50 aislada; acceso solo desde la VLAN 40 por TCP 5432; AWS RDS Multi-AZ; pg_dump diario hacia S3; reinicio automático de contenedores	Mitigar
R-02	Acceso no autorizado a datos personales	Alto	PR.AC-4, DE.CM-3	Usuarios de base de datos con mínimo privilegio; registros de auditoría en PostgreSQL; VPN cifrada; cumplimiento de la Ley N.º 29733	Mitigar
R-03	Fuerza bruta al API Gateway	Alto	PR.AC-1, DE.AE-2	WAF ModSecurity con límite de 100 req/s por IP; JWT de corta duración (15 minutos); bloqueo tras cinco intentos fallidos en el microservicio de autenticación	Mitigar
R-04	Inyección SQL vía microservicios	Alto	PR.DS-6, DE.AE-2	WAF ModSecurity con OWASP CRS bloquea inyecciones; ORM TypeORM con consultas parametrizadas en NestJS; validación de entradas en cada microservicio	Mitigar
R-05	Compromiso de credenciales de AD	Alto	PR.AC-1, PR.AC-6	Directiva de contraseñas: mínimo diez caracteres, complejidad y rotación de 90 días; bloqueo de cuenta tras cinco intentos; auditoría de inicio de sesión; autenticación multifactor pendiente para el siguiente semestre	Mitigar
R-06	Caída del ISP1 / WAN1	Alto	PR.IP-9, RS.RP-1	Dual-WAN en pfSense: el FortiGate 40F asume el tráfico en menos de diez segundos; <i>Dead Peer Detection</i> reconecta la VPN por la WAN secundaria	Mitigar
R-07	Fallo del respaldo pg_dump hacia S3	Alto	PR.IP-4, DE.CM-4	Alarma de CloudWatch si no se registra un <i>PutObject</i> en S3 entre las 22:00 y las 23:00; Wazuh alerta si el script de respaldo falla; sin respaldo on-premises alternativo –AWS es el único sitio de respaldo y recuperación– riesgo aceptado de RPO menor a 24 horas	Mitigar
R-08	Error de configuración en pfSense	Alto	PR.IP-1, PR.IP-3	Respaldo XML de pfSense antes de cada cambio; procedimiento formal de gestión de cambios; entorno de prueba separado pendiente	Mitigar

ID	Riesgo (resumen)	Nivel	NIST CSF	Control implementado o acción	Tratamiento
R-09	Falla del hipervisor H3	Medio	RC.RP-1, PR.IP-4	Conmutación a AWS: ECS Fargate para los microservicios y RDS Multi-AZ a través de Route 53, con un RTO aproximado de 15 minutos y un RPO menor a 24 horas, sin replicación en tiempo real; <i>snapshot</i> diario en ESXi	Mitigar
R-10	Caída de pfSense-BORDE	Medio	RS.MI-1, RC.RP	CARP en alta disponibilidad entre los nodos BORDE-A y BORDE-B con conmutación menor a dos segundos; <i>snapshot</i> diario de la VM; Local 1 y Local 3 operan localmente mediante RODC y servidor de archivos si la VPN cae	Mitigar
R-11	Interceptación de tráfico interlocal	Medio	PR.DS-2, PR.DS-5	VPN IPSec IKEv2 con AES-256-GCM siempre activa; <i>Dead Peer Detection</i> menor a 30 segundos; los datos sensibles solo viajan por la VPN según las reglas de pfSense	Mitigar
R-12	Caída del DNS francos.local sin un segundo controlador	Medio	PR.IP-9, RC.RP-1	Riesgo aceptado por decisión de diseño tras consolidar el respaldo y la recuperación en AWS, que no provee Active Directory; los RODC de Local 1 y Local 3 cubren solo autenticación local en caché; pfSense Unbound actúa como DNS terciario en caché	Aceptar
R-13	Exfiltración vía token JWT robado	Medio	PR.AC-4, PR.DS-5	JWT con vigencia de 15 minutos y <i>refresh token</i> ; revocación de tokens en el microservicio de autenticación; registros de acceso por usuario; HTTPS obligatorio	Mitigar
R-14	Ataque de denegación de servicio distribuido	Medio	PR.AC-5, RS.MI-1	CloudFront absorbe el tráfico mediante su red de distribución; <i>rate limiting</i> del WAF; verificación de estado de Route 53 redirige si el origen cae	Mitigar
R-15	Mensajes falsos en NATS	Medio	PR.AC-4, PR.DS-2	NATS aislado en la VLAN 40; solo se permite el tráfico desde la VLAN 30 hacia el puerto 4222; autenticación NKeys pendiente de configuración para el segundo semestre	Mitigar
R-16	Pérdida de conocimiento del equipo TI	Medio	PR.AT-1, PR.IP-11	Documentación técnica completa en archivos de especificación por hipervisor y sede, bitácoras operativas y repositorio de control de versiones	Mitigar

ID	Riesgo (resumen)	Nivel	NIST CSF	Control implementado o acción	Tratamiento
R-17	Acceso físico no autorizado al laboratorio	Medio	PR.AC-2	Control de acceso físico gestionado por la UPeU, fuera del alcance del proyecto; riesgo aceptado con justificación documentada	Aceptar
R-18	Corte eléctrico prolongado	Medio	PR.IP-9	UPS y grupo electrógeno gestionados por la UPeU, fuera del alcance del proyecto; riesgo aceptado; en una instalación real se contempla UPS dedicado y generador	Aceptar

E.1 Resultado del análisis de riesgos

El análisis identifica dieciocho riesgos: ocho de nivel alto y diez de nivel medio. Ningún riesgo alcanza nivel crítico, debido a que la arquitectura definida en el Entregable 1 ya implementa controles preventivos efectivos –Dual-WAN, CARP en alta disponibilidad, respaldo y recuperación ante desastres en AWS, WAF y controladores de dominio de solo lectura. De los dieciocho riesgos, quince se tratan mediante mitigación con controles técnicos y procedimentales, y tres se aceptan de forma documentada: el riesgo R-12, asociado a la ausencia de un segundo controlador de dominio on-premises tras la consolidación del respaldo en AWS, y los riesgos R-17 y R-18, asociados al acceso físico y a la energía del laboratorio de la UPeU, ambos fuera del control del proyecto.

Este resultado constituye el punto de partida del CE0323, donde cada riesgo a mitigar se traduce en una o más políticas formales de seguridad de la información.

CAPÍTULO F

Anexo F — Matriz RACI de Procesos de Seguridad

La matriz RACI—*Responsible, Accountable, Consulted, Informed*— asigna de forma explícita quién ejecuta, quién rinde cuentas, a quién se consulta y a quién se informa en cada proceso de seguridad. Esta matriz evita la ambigüedad de responsabilidades, particularmente en los procesos críticos de respuesta a incidentes y gestión de accesos.

Tabla 29. Matriz RACI de procesos de seguridad de la información

Proceso de seguridad	Gerencia	CISO	Admin. Red	Admin. Sistemas	DBA	Usuario
Definición y aprobación de políticas del SGSI	A	R	C	C	C	I
Gestión de accesos (alta, baja y modificación de cuentas AD)	I	A	R	C	–	I
Revisión trimestral de cuentas y accesos	I	A	R	C	C	–
Respaldo y recuperación de datos (<i>pg_dump, snapshots</i>)	–	A	C	R	R	–
Prueba de restauración de respaldos (trimestral)	I	A	C	R	R	–
Gestión de parches y actualizaciones	I	A	R	R	R	–
Monitoreo continuo (Wazuh y CloudWatch)	–	A	R	C	C	–
Detección y clasificación de incidentes (P1 a P4)	I	A	R	C	C	R
Respuesta y contención ante incidentes P1 o P2	A	R	R	R	R	I
Elaboración del análisis de causa raíz post-incidente	I	A	R	C	C	–
Evaluación de vulnerabilidades (revisión de CVE)	–	A	R	R	C	–
Capacitación anual de usuarios en seguridad	A	R	C	–	–	R
Notificación a INDECOPI por brecha de datos (Ley N.º 29733)	A	R	C	–	–	–

En la matriz, **R** corresponde a *Responsible* (quien ejecuta), **A** a *Accountable* (quien rinde cuentas, maximo uno por fila), **C** a *Consulted* (a quien se consulta) e **I** a *Informed* (a quien se informa); el guion indica que el rol no participa en ese proceso. Ruben Mark Salazar es *Accountable* en la mayoría de los procesos de seguridad, conforme al control A.6.1 de **(author?)** [3], mientras que Jorge Andres Chavarri Centeno participa como enlace organizacional en decisiones de impacto legal, documental o comunicacional.

Referencias Bibliográficas

- [1] International Organization for Standardization, “ISO/IEC 27005:2022 – Information security, cybersecurity and privacy protection – Guidance on managing information security risks,” standard, ISO/IEC, 2022.
- [2] National Institute of Standards and Technology, “The NIST Cybersecurity Framework (CSF) 2.0,” nist cswp 29, NIST, 2024.
- [3] International Organization for Standardization, “ISO/IEC 27001:2022 – Information security, cybersecurity and privacy protection – Information security management systems – Requirements,” standard, ISO/IEC, 2022.
- [4] Congreso de la República del Perú, “Ley N° 29733, Ley de Protección de Datos Personales.” Diario Oficial El Peruano, 2011.
- [5] P. A. Grassi, J. L. Fenton, E. M. Newton, R. A. Perlner, A. R. Regenscheid, W. E. Burr, and J. P. Richer, “Digital Identity Guidelines: Authentication and Lifecycle Management,” nist special publication 800-63b, National Institute of Standards and Technology, 2017.
- [6] M. Swanson, P. Bowen, A. W. Phillips, D. Gallup, and D. Lynes, “Contingency Planning Guide for Federal Information Systems,” nist special publication 800-34 rev. 1, National Institute of Standards and Technology, 2010.
- [7] Ministerio de Justicia y Derechos Humanos del Perú, “Decreto Supremo N° 003-2013-JUS, Reglamento de la Ley N° 29733, Ley de Protección de Datos Personales.” Diario Oficial El Peruano, 2013.
- [8] Association for Computing Machinery, “ACM Code of Ethics and Professional Conduct.” ACM, 2018.
- [9] Congreso de la República del Perú, “Ley N° 30096, Ley de Delitos Informáticos.” Diario Oficial El Peruano, 2013.